

BeCode Corp.

DFIR / SOC

Month 2 Security Assessment Report

Consolidated Assessment - INC-2026-004 to INC-2026-007

PREPARED FOR

NexaCorp Industries

Board review, 30 June 2026

Month 2 web application security assessment

Reference BCC-2026 | INC-2026-004 to 007

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 23 June 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
FINDINGS OF THE MONTH	6
Finding 04 - SQL Injection	6
Finding 05 - Command Injection and Web Shell	6
Finding 06 - XSS and Session Hijacking	6
Finding 07 - IDOR and Broken Access Control	7
ATTACK CHAIN NARRATIVE	8
RISK MATRIX	9
RECOMMENDATIONS	10
APPENDIX (TECHNICAL)	11

Confidentiality Statement

This Month 2 Security Assessment Report consolidates four incident investigations (INC-2026-004 to INC-2026-007) conducted for the fictitious client NexaCorp within the BeCode Corp internal cybersecurity training programme. It is intended for NexaCorp management and the board. No real production system, customer data, or third-party infrastructure was involved.

The report is classified Confidential, do not distribute outside BeCode Corp, under reference BCC-2026 | INC-2026-004 to 007. Raw evidence (logs, network captures, exports) is retained by BeCode Corp and is not redistributed. Per-incident technical detail is in the individual reports INC-2026-004 through INC-2026-007.

Executive Summary

Over four weeks in June 2026, NexaCorp's web application layer was the target of **four connected security incidents (INC-2026-004 to INC-2026-007)**. They are not four separate events : they are one adversary, operating from a single internet source, progressing step by step from an initial break-in to a confirmed theft of employee personal data.

Key numbers for the month:

- **4 incidents**, one continuous campaign, same external source throughout.
- **1 employee credential** stolen and cracked, then reused to gain a foothold.
- **1 unauthorized backdoor account** created inside the portal and, critically, **never removed**.
- **1 employee session** hijacked.
- **47 employee records** exfiltrated (name, email, department, job title, phone, salary band), including senior executives and the company's own Data Protection Officer.

Is a GDPR notification required? Yes.

Incident INC-2026-007 is a confirmed exfiltration of identifiable personal data affecting 47 data subjects. Under GDPR Article 33, NexaCorp must notify the supervisory authority (for a Belgian establishment, the Data Protection Authority / Autorite de protection des donnees) without undue delay and, where feasible, within **72 hours** of confirming the breach. Communication to affected individuals (Article 34) should be assessed in parallel.

The single most important point

The root cause of the final and most damaging incident is **not** a new technical flaw. It is an **operational failure : the attacker's backdoor account was left in place** after the earlier incidents were closed. NexaCorp correctly applied every technical fix recommended along the way - the SQL injection was patched, the compromised address was blocked, the developer's password was rotated, and the cross-site scripting flaw was mitigated. Those fixes worked. They did not matter, because the attacker still held a valid login that nobody removed. The final breach required no exploit at all.

Recommended immediate actions:

- Remove the unauthorized account and audit the portal for any other account that does not belong.
- Proceed with the GDPR breach notification.
- Enforce proper authorization checks on the portal (who may see and export what).
- Add behaviour-based monitoring : the campaign was largely invisible to current alerting.

Findings of the Month

Finding 04 - SQL Injection (INC-2026-004)

Risk rating:

CRITICAL

Technique:

SQL injection against the employee portal login / lookup form

Component:

employee portal database (bru-web-01)

Data impacted:

the full user table was extracted; a developer account with a weak password was cracked offline and reused over SSH

Business impact. Confirmed theft of stored credentials and an authenticated entry point into NexaCorp's environment.

Finding 05 - Command Injection and Web Shell (INC-2026-005)

Risk rating:

CRITICAL

Technique:

operating-system command injection via the portal diagnostic tools (remote code execution); a file-viewer flaw was probed but disclosed nothing

Exploitation path:

the INC-2026-004 foothold was reused to run commands as the web server account, read the server account file, and plant a hidden web shell

Persistence established:

a web shell on the server plus interactive SSH access; an unauthorized account is introduced into the portal at this stage

Business impact. Full remote control of the portal server and durable, attacker-controlled access.

Finding 06 - XSS and Session Hijacking (INC-2026-006)

Risk rating:

HIGH

Technique:

stored cross-site scripting (XSS) in the NexaPortal feedback feature

Victim account:

an Office Management employee whose active session was stolen on viewing the malicious entry

Session data exposed:

the victim session identifier was sent to an attacker server, enabling impersonation without a password

Business impact. Account impersonation. NexaCorp responded with the correct fixes (HttpOnly cookies, Content Security Policy), which closed this technique.

Finding 07 - IDOR and Broken Access Control (INC-2026-007)

Risk rating:

CRITICAL

Technique:

Insecure Direct Object Reference (IDOR) plus broken access control on NexaPortal

Scope of exposure:

the still-active unauthorized account read the entire employee directory (47 records) one at a time

Admin access confirmed:

the administrative export page returned data to a non-administrator session; a full employee export was downloaded

Business impact. Confirmed exfiltration of 47 employees' personal data. This is the incident that triggers the GDPR obligation.

Attack Chain Narrative : one adversary, four steps

The four incidents are a single, connected progression carried out by the same actor from the same external source:

- **INC-2026-004 (SQL injection).** The attacker breaks into the portal database and steals employee credentials. One developer password is weak, is cracked, and is reused to log in to the server.
- **INC-2026-005 (command injection and web shell).** Using that access, the attacker runs commands on the server, plants a web shell, and **inserts an unauthorized backdoor account** into the portal. The foothold is now durable and identity-based.
- **INC-2026-006 (XSS and session hijacking).** The backdoor account is used to steal a colleague's session. NexaCorp detects the theft and applies the recommended fixes, blocks the attacker's known address, and rotates the cracked password. **The backdoor account is not removed.**
- **INC-2026-007 (IDOR and broken access control).** The backdoor account simply logs in again, walks the employee directory, opens an unprotected admin page, and exports 47 employees' personal data. No exploit is needed.

The connecting thread is the un-removed backdoor account. Each individual fix was correct, but the campaign continued because the attacker's identity inside the application survived every remediation. Closing an incident must include removing the access the attacker established, not only patching the flaw that was used.

Risk Matrix

Each finding plotted by business Impact against Likelihood of recurrence. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				F04, F05, F07	
High (4)			F06		
Medium (3)					
Low (2)					
Very Low (1)					

Critical	High	Medium	Low
----------	------	--------	-----

F04, F05 and F07 sit in the top-right (Critical): confirmed credential theft, remote code execution, and confirmed personal-data exfiltration. **F06 (High)** is lower in likelihood because its technique has been mitigated, but it remains part of the same chain.

Recommendations

Immediate (this week)

- **Remove the unauthorized account and audit the portal user list** against the official IT account register; remove anything that does not match. Addresses the root cause of INC-2026-007.
- **Proceed with the GDPR Article 33 notification** and assess Article 34 communication to the 47 affected employees.

Short term (this month)

- **Enforce authorization on the portal** : verify a user may see each record requested (fixes IDOR) and that only administrators can reach admin pages and exports (fixes broken access control).
- **Eliminate the injection classes at the source** : parameterised database queries (Finding 04); remove or strictly control the diagnostic command and file features (Finding 05).
- **Enforce strong credential hygiene** : block weak and breached passwords, migrate to a modern salted hash, require multi-factor authentication (Finding 04).

Strategic (this quarter)

- **Add behaviour-based detection** for directory enumeration, non-administrator access to admin and export functions, and credential reuse. The campaign was largely invisible to current monitoring.
- **Change the incident-closure process** : an incident is not closed until the access the attacker established (accounts, web shells, scheduled tasks) is removed and verified, not only the exploited flaw patched.

Appendix (technical)

Indicators of compromise (campaign)

- Attacker source address 172.16.50.10, used across INC-2026-004, 005 and 007.
- Unauthorized portal account m.renard (backdoor), introduced at INC-2026-005 and reused at INC-2026-006 and 007.
- Web shell planted on the portal server (INC-2026-005).
- External collection server 91.92.100.45:8080 receiving the stolen session (INC-2026-006).
- Portal endpoints abused at INC-2026-007 : /portal/employees.php (IDOR), /portal/admin/, /portal/admin/export_users.php.

Detection coverage (INC-2026-007 window)

The SIEM raised 211 alerts, all against unrelated scanner traffic (Wazuh rules 31101, 31108, 31151). The actual attack produced no alerts, because every request succeeded under a valid, authenticated session. This is itself a finding and is the basis for the behavioural-detection recommendation.

Source material

Per-incident technical detail, exact timestamps, payloads and evidence references are in the individual incident reports INC-2026-004 through INC-2026-007. Raw evidence is retained by BeCode Corp and is not redistributed.

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | Month 2 Assessment (INC-2026-004 to 007)

Classification: Confidential, do not distribute outside BeCode Corp

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi